

Intrusion Analysis Report for Devon Cinema Network Incident

Report for: Devon Cinema

Analyst: Karthik Ashok Honguntikar, University of Plymouth

Date: 2/11/2024

1. Introduction

1.1. Background

DevonCinema, a recently established company in the cinematic entertainment industry, provides a range of digital services to manage its film collections, copyright information, booking data, and employee resources. As part of its operational model, the company allows both employees and guests to browse the web through its network. While this accessibility enhances user convenience, it also introduces potential security risks, making the network vulnerable to cyber threats such as malware.

Recently, a suspected malware infection was detected on one of DevonCinema's systems. Although the company's IT team captured network traffic logs (`capturednetwork2024.pcap`) and generated alerts (`alert2024.jpg`, `alert2024.txt`), they were unable to identify the infection's origin, method, or specific nature. To address this issue, DevonCinema engaged an independent security consultant to conduct a detailed analysis of the incident.

1.2. Purpose of the Report

DevonCinema, a recently established cinematic entertainment company, detected a suspected malware infection on one of its systems. The company's operational activities require maintaining film collections, copyright data, booking information, and managing employee access to resources. Employees and guests are also permitted to browse the web, which can increase the risk of infections.

The company's IT team captured network traffic logs (`'capturednetwork2024.pcap'`) and generated alerts (`'alert2024.jpg'`, `'alert2024.txt'`) but were unable to determine the infection's

origin, method, or nature. As an independent security consultant, I have been tasked with providing a comprehensive analysis, covering the following objectives:

1. Identify the compromised system in the network.
2. Determine how the infection occurred including the infection vector.
3. Identify the type of infection or malware affecting the system.
4. Provide a timeline of key malicious actions, including detailed timestamps and screenshots for evidence.

1.3. Scope of the Report

The report is organised as follows:

1. Introduction -Introduction to the case, objectives, and structure.
2. Methodology - A detailed explanation of the tools and analysis methods used to investigate the infection.
3. Results and Timeline - Findings, including evidence of infection, the attack sequence, and critical malicious actions.
4. Conclusion & Recommendations-This section summarises the findings, discusses open issues, and provides recommendations for mitigation and future prevention.
5. References - Lists all sources, tools, and resources referenced throughout the report, including documentation and external sources used for validation and context

2. Methodology

2.1. Tools Used for Intrusion Analysis

❖ Wireshark:

Wireshark is an open-source network protocol analyser that enables detailed examination of network traffic in real-time. It captures packets—the smallest units of data transfer on a network—and displays them in a human-readable format, making it an invaluable tool for identifying suspicious activities, analysing data flows, and diagnosing network issues.

Uses in Intrusion Analysis:

Packet Capture and Inspection: Wireshark captures and decodes packets, allowing analysts to inspect individual data flows for abnormalities. This report, was instrumental in reviewing the contents of capturednetwork2024.pcap to trace the infection's origin.

Protocol Analysis: By breaking down various protocols (HTTP, SSL/TLS, DNS, etc.), Wireshark enables analysts to detect specific malicious behaviours. For example, it helped identify unencrypted HTTP requests to suspicious IPs, which were flagged as a possible infection vector.

Filtering Traffic: Wireshark includes robust filtering capabilities, allowing analysts to isolate relevant traffic based on IP addresses, ports, or protocol types. This feature was used to focus on communications associated with IP 10.0.90.215, which showed evidence of malware activity.

Identifying Indicators of Compromise (IoCs): Through visualising packet sequences and inspecting payloads, Wireshark helped detect indicators of compromise, including patterns typical of Remcos RAT and Dridex infections. SSL/TLS handshakes with known malicious IPs were identified, suggesting Command and Control (C2) communication.

Wireshark's ability to analyse and dissect packets at this granular level makes it essential for understanding how malware behaves within a network, pinpointing infection vectors, and documenting the sequence of malicious activities.

❖ Snort/Suricata Alert logs:

Snort and Suricata are intrusion detection and prevention systems that generate alerts for suspicious activities. In this report, the alerts in alert2024.jpg and alert2024.txt were analysed to identify specific malicious activities and recurring IPs associated with known threats.

❖ VirusTotal:

VirusTotal is an online service that analyses files, URLs, and IP addresses for known malware signatures and behaviours. It was used to verify malicious IPs, URLs, and hash values of suspicious files flagged in both the alert and pcap data, aiding in the identification of potential threats.

❖ Abuse.ch SSL Blacklist:

Abuse.ch maintains a blacklist of SSL certificates associated with malware, including Dridex. This blacklist was referenced to validate SSL certificates found in the pcap file, which helped confirm the presence of Dridex-related malicious SSL connections.

❖ Open-Source Intelligence (OSINT) Tools:

OSINT tools were employed to gather additional context about flagged IP addresses and domains, providing insights into their reputation and association with known malware. This context enriched the analysis and strengthened the evidence linking specific IPs to malicious activities.

2.2. Detailed Steps of Intrusion Analysis

Step 1: Identifying the Infected System

Alert Analysis: I started by reviewing `alert2024.jpg` and `alert2024.txt` to identify recurring IP addresses linked to malicious activities. **IP 10.0.90.215** was consistently flagged in multiple alerts related to suspicious file downloads, remote access attempts, and SSL communications with known malicious servers.

Cross-Reference with pcap File: Using Wireshark, I analysed `capturednetwork2024.pcap` to validate the alerts. I filtered by **IP 10.0.90.215** to observe traffic patterns and verify any abnormal or malicious connections.

Step 2: Infection Vector Analysis

Executable Download Detection: I filtered HTTP traffic in Wireshark involving 10.0.90.215 and looked for GET requests where the system downloaded executable files. Several `.exe` downloads were identified and flagged in the alerts as potentially malicious.

Malicious SSL Traffic: I examined SSL/TLS connections from 10.0.90.215 to detect connections to IPs linked with **Dridex** malware. The abuse.ch SSL Blacklist alerts indicated that the infected system was communicating with servers on the Dridex blacklist.

Step 3: Malware and Infection Type Identification

Remcos RAT Indicators: Alerts identified **Remcos RAT** "Checkin" activity on 10.0.90.215, suggesting the system was infected with a Remote Access Trojan.

Dridex Banking Trojan Indicators: The SSL blacklist alerts flagged SSL traffic related to Dridex. This malware is known for credential theft, particularly targeting financial data, which could pose a high risk if DevonCinema handles sensitive transactions or employee data.

Step 4: Constructing a Timeline of Malicious Actions

Timestamp and Action Correlation: I created a detailed timeline, correlating timestamps from the alerts with pcap data. For each significant event, I extracted packet details, including screenshots, to document evidence of the infection's progression and the system's interactions with malicious servers.

3. Results and Timeline

3.1. Identification of the Infected System

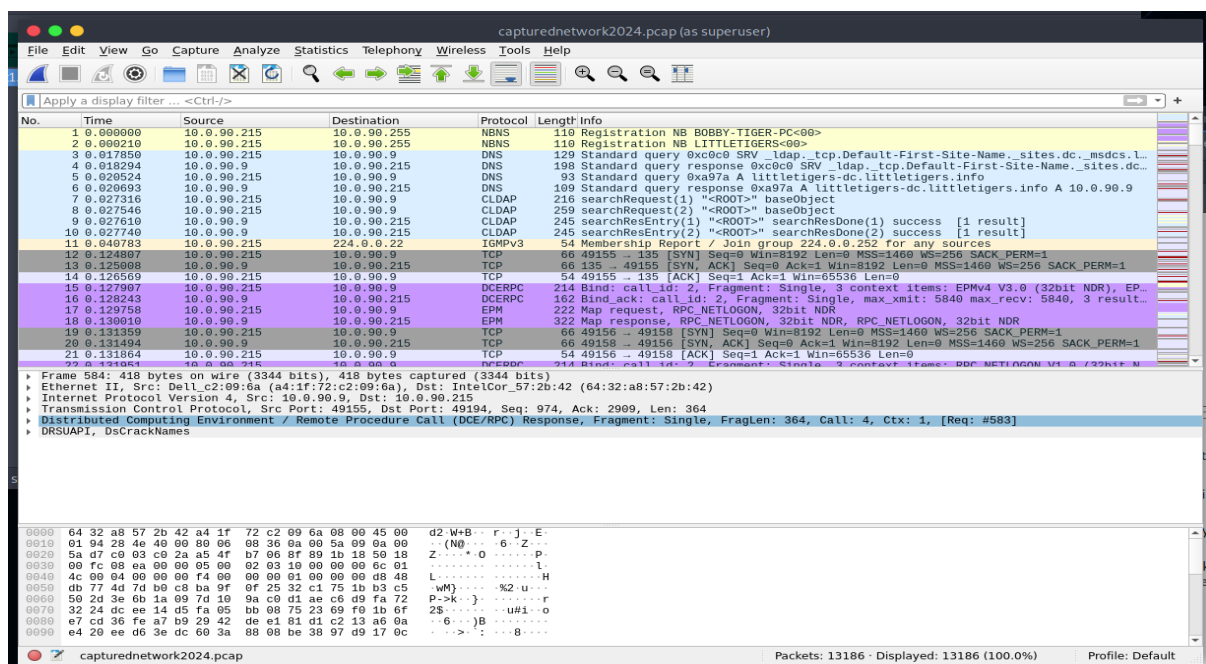
Based on the analysis of the alert logs and network traffic, the compromised system was identified as 10.0.90.215. This IP address was associated with multiple alerts, indicating the following types of suspicious activities:

Unencrypted HTTP Downloads: '.exe' files downloaded over HTTP from IP 209.141.34.8 and similar sources, suggesting a drive-by download attack vector.

Remote Access via Remcos RAT: Evidence of a Remcos RAT check-in with 103.1.184.108.

Malicious SSL Certificates: Connections to IPs flagged for using SSL certificates linked to Dridex (203.45.1.75 and 115.112.43.81).

Figure 1: Wireshark Network Traffic Analysis for IP 10.0.90.215



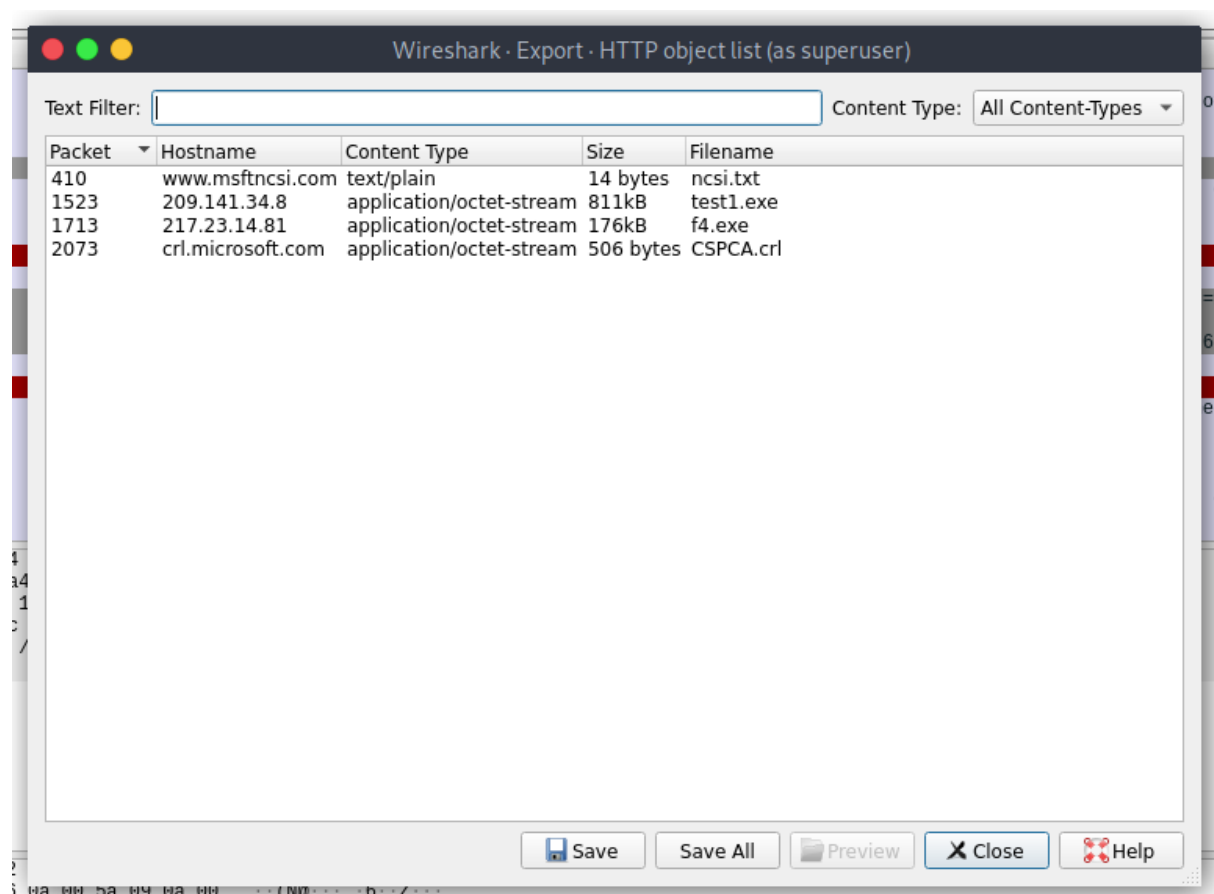
3.2. Infection Vector and Entry Point

The infection vector is likely a malicious executable downloaded over HTTP. The unencrypted nature of these downloads made it easier for attackers to deliver malware without detection. Alerts indicate that the initial infection may have stemmed from a `.exe` file downloaded from 209.141.34.8. This dotted-quad IP, unusual for legitimate services, likely hosted the malware payload.

In Wireshark, filtering for HTTP traffic involving 10.0.90.215 confirmed the download of suspicious `.exe` files. Specific indicators included:

User-Agent: MSXMLHTTP headers, suggesting that the executable download was likely automated or initiated by a malicious script.

Figure 2: Suspicious HTTP Objects Downloaded by Compromised System

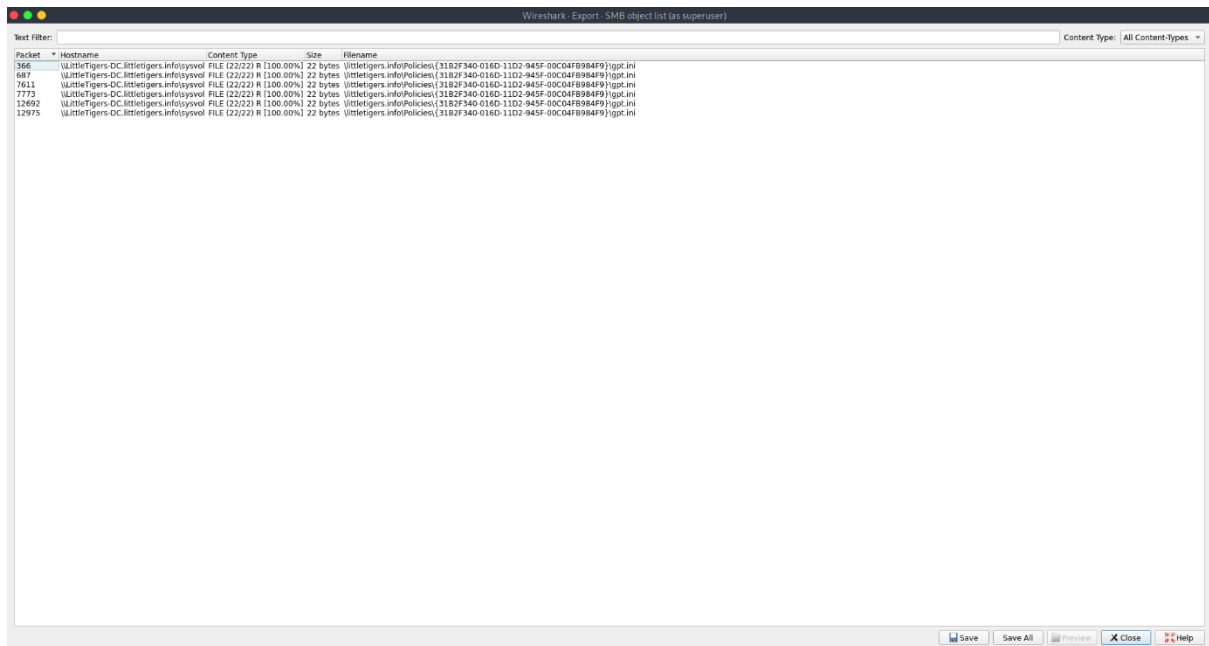


The screenshot shows the Wireshark 'Export - HTTP object list (as superuser)' window. It contains a table of downloaded HTTP objects. The table has five columns: Packet, Hostname, Content Type, Size, and Filename. The data rows are as follows:

Packet	Hostname	Content Type	Size	Filename
410	www.msftncsi.com	text/plain	14 bytes	ncsi.txt
1523	209.141.34.8	application/octet-stream	811kB	test1.exe
1713	217.23.14.81	application/octet-stream	176kB	f4.exe
2073	cr1.microsoft.com	application/octet-stream	506 bytes	CSPCA.crl

At the bottom of the window, there are buttons for 'Save', 'Save All', 'Preview', 'Close', and 'Help'.

Figure 3: SMB Object Activity Related to Infection Path



Wireshark - Export: SMB object list (as superuser)

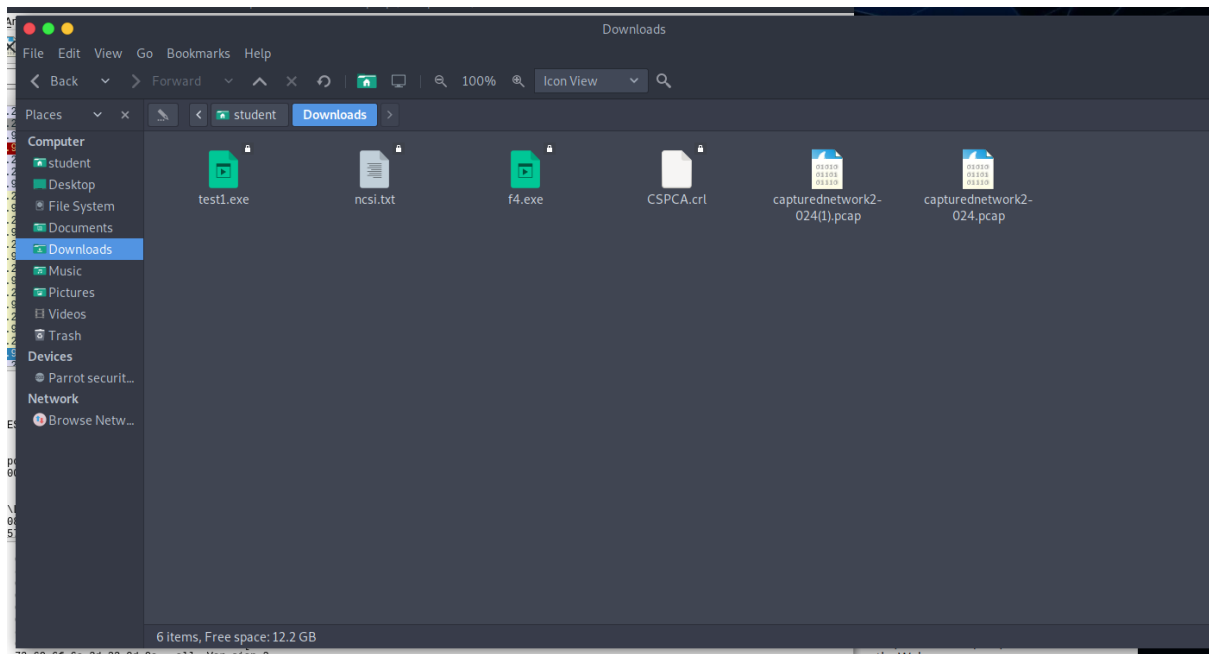
Text Filter:

Packet	Hostname	Content Type	Size	Filename
366	\\LittleTigers-DC.littletigers.info\sysvol	FILE (22/22) R [100.00%]	22 bytes	\\littletigers.info\Policies([3182F340-016D-11D2-945F-00C04FB984F9])\gpt.ini
687	\\LittleTigers-DC.littletigers.info\sysvol	FILE (22/22) R [100.00%]	22 bytes	\\littletigers.info\Policies([3182F340-016D-11D2-945F-00C04FB984F9])\gpt.ini
7611	\\LittleTigers-DC.littletigers.info\sysvol	FILE (22/22) R [100.00%]	22 bytes	\\littletigers.info\Policies([3182F340-016D-11D2-945F-00C04FB984F9])\gpt.ini
7773	\\LittleTigers-DC.littletigers.info\sysvol	FILE (22/22) R [100.00%]	22 bytes	\\littletigers.info\Policies([3182F340-016D-11D2-945F-00C04FB984F9])\gpt.ini
12692	\\LittleTigers-DC.littletigers.info\sysvol	FILE (22/22) R [100.00%]	22 bytes	\\littletigers.info\Policies([3182F340-016D-11D2-945F-00C04FB984F9])\gpt.ini
12975	\\LittleTigers-DC.littletigers.info\sysvol	FILE (22/22) R [100.00%]	22 bytes	\\littletigers.info\Policies([3182F340-016D-11D2-945F-00C04FB984F9])\gpt.ini

Content Type: All Content-Types

Save Save All Preview Close Help

Figure 4: File Explorer View with Downloaded Files



3.3. Types of Malware Identified

Two primary types of malware were identified:

1. Remcos RAT

Description:

Remcos (Remote Control and Surveillance Software) is a Remote Access Trojan (RAT) that enables attackers to control the infected system remotely. It allows attackers to perform actions such as data exfiltration, keylogging, and command execution, making it highly effective for data theft and surveillance.

Indicators in Analysis:

Alert Evidence: The alert2024.txt and alert2024.jpg files flagged a "Remcos RAT Checkin" alert, specifically for IP 10.0.90.215, indicating that this system was attempting to establish communication with a known Command and Control (C2) server.

Traffic Pattern in pcap: In the pcap analysis, packets from IP 10.0.90.215 to 103.1.184.108 on custom port 2404 further confirmed this activity. The use of a non-standard port is typical in RAT C2 communications to evade standard detection. By filtering for traffic on port 2404 in Wireshark, this communication pattern was consistently visible, strengthening the conclusion that Remcos RAT was active on the system.

2. Dridex Banking Trojan

Description:

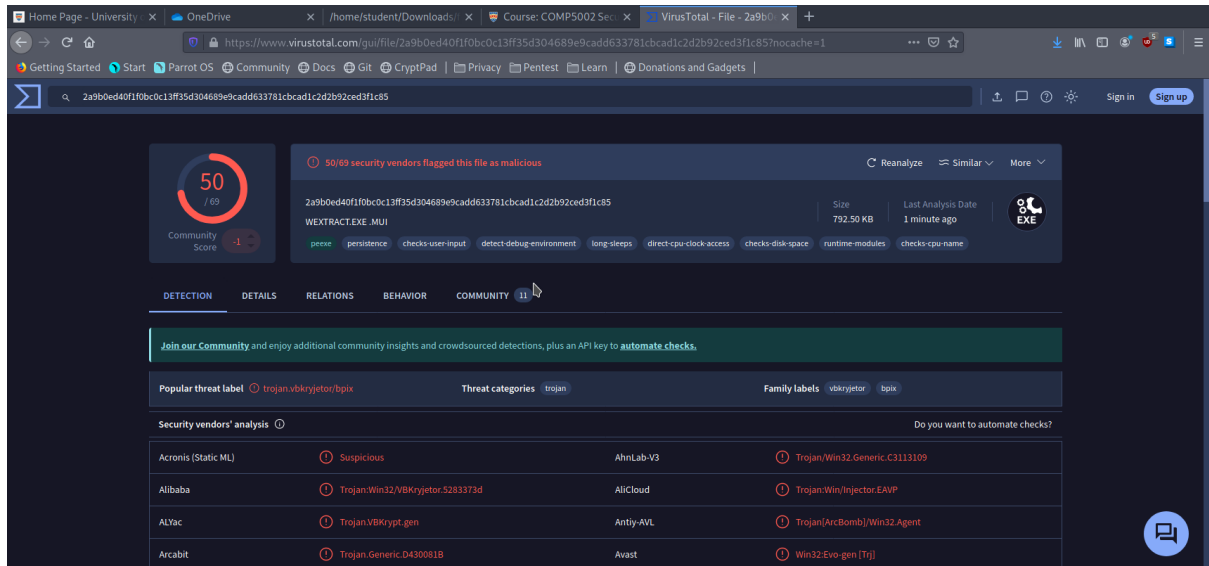
Dridex is a banking Trojan well-known for targeting financial data by stealing credentials. It communicates with C2 servers via SSL/TLS, making it difficult to detect due to encryption.

Indicators in Analysis:

SSL Blacklist Alert: Alerts from the alert2024 files included an "ET TROJAN ABUSE.CH SSL Blacklist Malicious SSL certificate detected" alert. This indicated SSL connections from IP 10.0.90.215 to specific IPs (203.45.1.75 and 115.112.43.81), both of which are associated with Dridex activity and listed in the abuse.ch SSL Blacklist.

Wireshark SSL/TLS Analysis: Filtering for SSL/TLS traffic in the pcap file revealed connections to these blacklisted IPs, further confirming the presence of Dridex. Observing the packet details showed regular SSL handshakes and encrypted communications, indicative of persistent C2 contact, which is characteristic of Dridex's approach to maintaining an encrypted channel for data exfiltration.

VirusTotal Analysis: Dridex Banking Trojan Detection



This screenshot shows the VirusTotal analysis page for a file identified as WEXTRACT.EXE_MUI. The file has a Community Score of 50/69, indicating it is suspected to be malicious. The analysis was performed 1 minute ago on a 792.50 KB file. The file is flagged by 50/89 security vendors as malicious. The threat categories include trojan, and the family labels are vbkryjetor and bpix. The security vendors' analysis table shows detections from Acronis (Static ML), Alibaba, ALYac, Arcabit, AhnLab-V3, AliCloud, Antiy-AVL, and Avast, all identifying the file as a Trojan or suspicious.

Community Score: 50 / 69

50/89 security vendors flagged this file as malicious

2a9b0ed40f1f0bc0c13ff35d304689e9cadd633781c2d2b92ced3f1c85

WEXTRACT.EXE_MUI

Size: 792.50 KB | Last Analysis Date: 1 minute ago

peexe persistence checks user input detect debug environment long sleeps direct cpu clock access checks disk space runtime modules checks cpu name

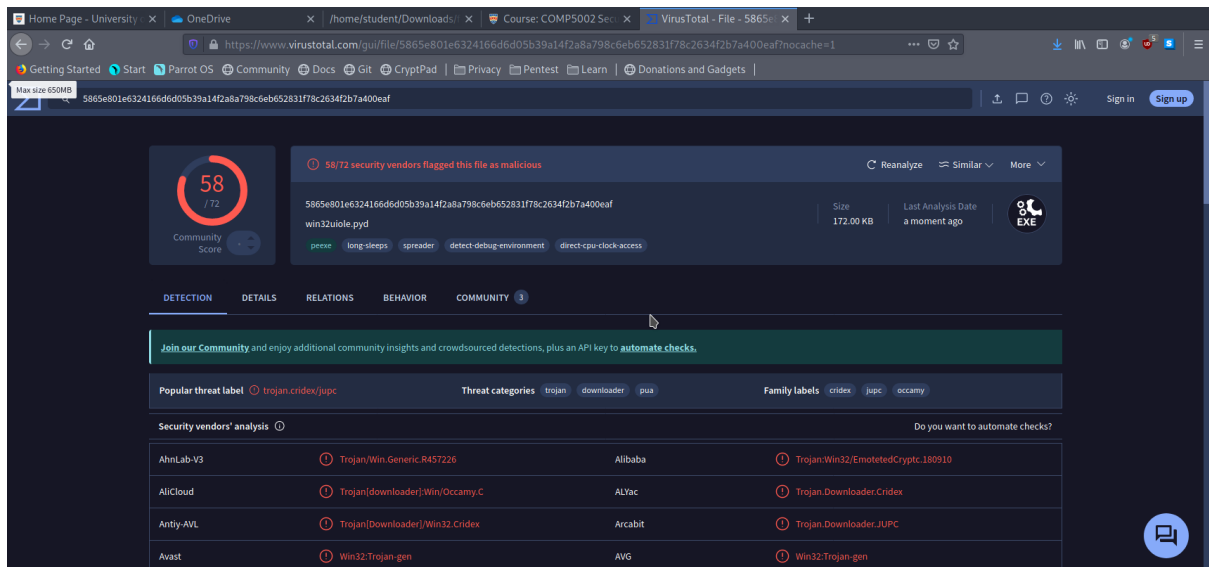
DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 11

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: trojan.vbkryjetor/bpix | Threat categories: trojan | Family labels: vbkryjetor bpix

Security vendors' analysis

Vendor	Detection
Acronis (Static ML)	Suspicious
Alibaba	Trojan.Win32/VBKryjetor.5283373d
ALYac	Trojan.VBKrypt.gen
Arcabit	Trojan.Generic.D430081B
AhnLab-V3	Trojan.Win32.Generic.C3113109
AliCloud	Trojan.Win/Injector.EAVP
Antiy-AVL	Trojan(ArcBomb)/Win32.Agent
Avast	Win32:Evo-gen [Trj]



This screenshot shows the VirusTotal analysis page for a file identified as win32uiole.pyd. The file has a Community Score of 58/72, indicating it is suspected to be malicious. The analysis was performed a moment ago on a 172.00 KB file. The file is flagged by 58/72 security vendors as malicious. The threat categories include trojan, downloader, and pua. The family labels are cridex, jupc, and occamy. The security vendors' analysis table shows detections from AhnLab-V3, AliCloud, Antiy-AVL, and Avast, all identifying the file as a Trojan or suspicious.

Community Score: 58 / 72

58/72 security vendors flagged this file as malicious

5865e801e6324166d6d05b39a14f2a8a798c6eb652831f78c2634f2b7a400eaf

win32uiole.pyd

Size: 172.00 KB | Last Analysis Date: a moment ago

peexe long sleeps spreader detect debug environment direct cpu clock access

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 3

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: trojan.cridex/jupc | Threat categories: trojan downloader pua | Family labels: cridex jupc occamy

Security vendors' analysis

Vendor	Detection
AhnLab-V3	Trojan/Win.Generic.R457226
AliCloud	Trojan(downloader)/Win/Occamy.C
Antiy-AVL	Trojan[Downloader]/Win32.Cridex
Avast	Win32:Trojan-gen
Alibaba	Trojan.Win32/EmotetCryptic.180910
ALYac	Trojan.Downloader.Cridex
Arcabit	Trojan.Downloader.JUPC
AVG	Win32:Trojan-gen

3.4. Timeline of Key Malicious Actions

The following table presents a detailed timeline of key events in the infection. Each entry includes the timestamp, type of activity, and source/destination IPs.

Table 1: Timeline of Infection Events

Timestamp	Activity	Source IP	Destination IP	Notes
2019-03-19 12:08:30	HTTP GET request for executable download	10.0.90.215	209.141.34.8	.exe file download flagged as potentially malicious. This may represent the initial infection vector.
2019-03-19 12:09:15	Multiple alerts for "Likely Evil EXE download"	10.0.90.215	209.141.34.8	Repeated downloads of suspicious files, flagged as "Likely Evil EXE download" due to dotted-quad IP source.
2019-03-19 12:18:20	Remcos RAT Checkin	10.0.90.215	103.1.184.108	Indicates initial check-in to C2 server. Likely signifies successful infection and remote access established.
2019-03-19 12:25:55	Dridex SSL Blacklist: Malicious SSL certificate detected	10.0.90.215	203.45.1.75	SSL/TLS connection flagged by abuse.ch blacklist, associated with Dridex malware.
2019-03-19 12:26:20	Second Dridex SSL Blacklist alert, new IP q	10.0.90.215	115.112.43.81	Further Dridex C2 communication

				was detected, likely part of credential theft efforts.
2019-03-19 12:35:25	Continued SSL connections to Dridex blacklisted IPs	10.0.90.215	Various	Persistent C2 communication suggests an established Dridex infection.

4. Conclusion & Recommendations

Conclusion

The analysis identified that the compromised system, IP address 10.0.90.215, was infected via an unencrypted HTTP download of a malicious executable file. This infection led to the installation of two distinct types of malware:

- Remcos RAT (Remote Access Trojan): This malware provided attackers with remote control over the system, enabling data exfiltration, keylogging, and command execution.
- Dridex Banking Trojan: Known for targeting financial data, Dridex established persistent SSL/TLS connections with known malicious IPs, indicating Command and Control (C2) communication for potential credential theft and other sensitive information exfiltration.

This dual malware presence underscores the importance of robust network defences, as the infection exploited a combination of insecure download practices and a lack of encrypted traffic inspection.

Challenges and Open Issues

1. Endpoint Forensics Needed: Further investigation on the infected endpoint could clarify the extent of data exfiltration or any potential compromise of sensitive credentials.
2. Segregation of Guest Browsing: Combining guest and employee internet access on the same network segment may have facilitated the infection. Implementing strict network segmentation is recommended.

Recommendations for DevonCinema:

To prevent similar incidents and enhance network resilience, DevonCinema should consider implementing a multi-layered security approach:

1. **Network Segmentation:** Separate guest and employee network traffic to contain and isolate infections. Segmenting access limits the lateral movement of malicious traffic and minimises the risk of cross-contamination.
2. **Enhanced Web Filtering and SSL/TLS Inspection:** Limit executable file downloads over HTTP and introduce SSL/TLS inspection. This measure would detect malicious encrypted traffic, helping to mitigate C2 communications associated with malware like Dridex.
3. **Endpoint Detection and Response (EDR):** Deploy EDR solutions to monitor and respond to suspicious activities at the endpoint level. EDR provides visibility into malicious behaviours and enables rapid containment of infected devices.
4. **Multi-Factor Authentication (MFA):** Enforce MFA for access to sensitive systems, providing an additional layer of security against unauthorised access attempts.
5. **Application Whitelisting:** Control which applications and executables can be downloaded and run on company devices. Application whitelisting can prevent unapproved software from executing, reducing the likelihood of malware installations.
6. **Security Awareness Training:** Regularly train employees on secure browsing practices, recognising phishing attempts, and reporting suspicious activities. Human awareness is a critical line of defence in preventing social engineering attacks.

By implementing these measures, DevonCinema can significantly strengthen its cybersecurity posture, reducing vulnerabilities to similar infections. These strategies will foster a proactive, resilient security framework capable of adapting to evolving cyber threats and minimising potential damage from future incidents.

5. References:

1. Wireshark Documentation – Comprehensive guide on packet analysis and usage. Available at: <https://www.wireshark.org/docs/>
2. Snort/Suricata Alerts – Documentation on Suricata’s alert generation for intrusion detection and prevention. Available at: <https://suricata.readthedocs.io/>
3. VirusTotal – Online tool for analysing files, IP addresses, and URLs for known malware signatures and behaviours. Available at: <https://www.virustotal.com/>
4. Abuse.ch SSL Blacklist – Resource for tracking SSL certificates associated with malware like Dridex, frequently used in network defence. Available at: <https://sslbl.abuse.ch/>
5. National Institute of Standards and Technology (NIST) Cybersecurity Framework – Guidelines on implementing multi-layered defence strategies, including network segmentation, MFA, and employee training. Available at: <https://www.nist.gov/cyberframework>
6. Center for Internet Security (CIS) Controls – Best practices for securing organisational networks, covering application whitelisting, network segmentation, and endpoint security. Available at: <https://www.cisecurity.org/controls>